Password Strength – Broken Authentication

Application: OWASP Juice Shop

Objective

To analyze weaknesses in password policy and demonstrate how poor password strength leads to broken authentication.

Tools Used

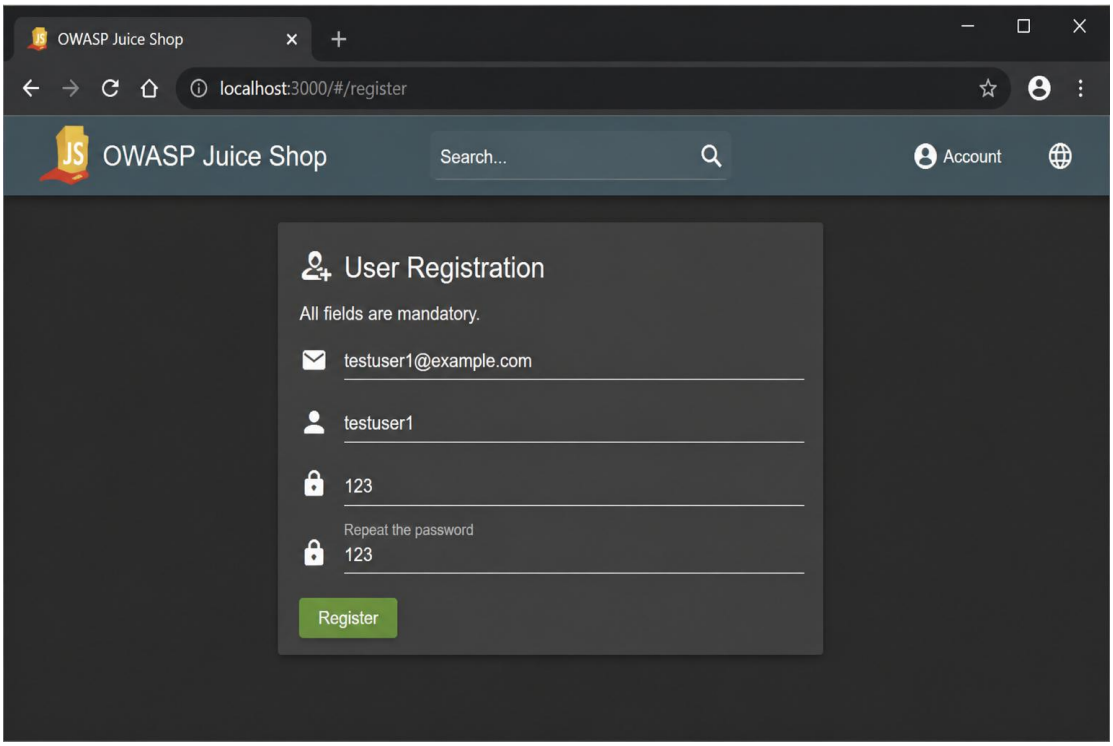
- Web Browser (Chrome/Firefox)
- Burp Suite (optional for observation)

Lab Description

The application allows users to register or change passwords.
The goal is to check whether the system enforces **strong password rules**.

Procedure

1. Open Juice Shop application
2. Navigate to **Register / Login page**
3. Try entering:
    - Very short passwords
    - Common passwords (like simple patterns)
4. Observe system response
5. Check whether password strength is enforced



Observation

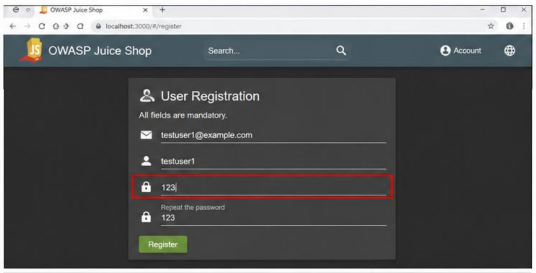
- Weak passwords are accepted (or not strictly validated)
- No strong enforcement like:
    - Minimum length
    - Special characters
    - Complexity rules
- No feedback or weak validation messages

Result

The application demonstrates **Broken Authentication** because it allows weak passwords, making accounts vulnerable to attacks like guessing and brute force.

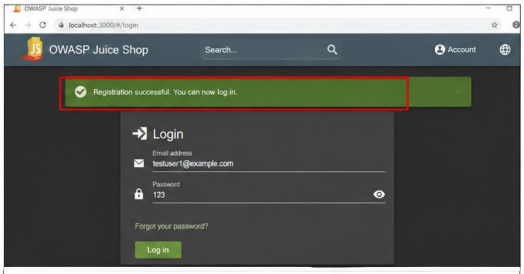
Password Strength – Broken Authentication | OWASP Juice Shop
Lab Report – Screenshot Reference

1. Registration Page – Entering Weak Password



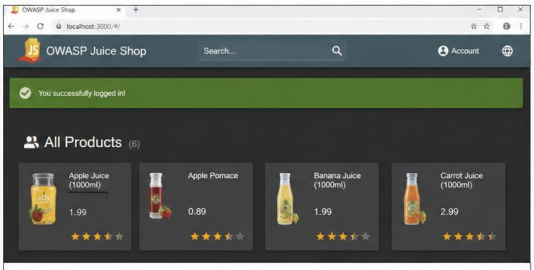
Weak password (123) entered in the registration form.

2. Weak Password Accepted Successfully



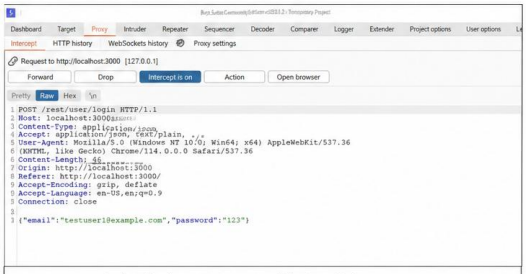
Application accepts the weak password and user is registered successfully.

3. Login Successful Using Weak Password



Login successful with weak password (123).

4. (Optional) Burp Suite – Authentication Request Intercepted



Authentication request captured in Burp Suite.

Impact

- Accounts can be easily compromised
- Attackers can guess passwords quickly
- User data may be exposed

Prevention

- Enforce strong password policy:
    - Minimum 8–12 characters
    - Uppercase + lowercase + numbers + symbols
- Use password strength meter
- Block common passwords
- Implement multi-factor authentication